CLOUD IAM SECURITY & MONITORING LAB

October 2026

Nexora Systems - Simulated Cloud Environment.

Identity & Access Management, Security Monitoring & Misconfiguration Remediation.

Project Implementation & Technical Report by: Rahul Reghu Rajan

AUTHOR INFORMATION

Author: Rahul Reghu Rajan
Qualification: Bachelor of Computer Applications (BCA)
Certification: Certified Ethical Hacker (CEH V13)

Rahul Reghu Rajan is a cybersecurity practitioner with a focus on security monitoring, threat detection, vulnerability assessment, wireless security, and threat intelligence. His work emphasizes practical security implementations, risk analysis, and security automation through hands-on cybersecurity projects.

The project was designed and implemented as a controlled cybersecurity lab to examine IAM misconfiguration, validate cross-team access restrictions, investigate audit evidence, and verify remediation.

DISCLAIMER & SCOPE

This report documents a controlled cloud security lab developed for educational and portfolio purposes. The assessment was conducted within an AWS environment configured by the author, using test identities, resources, and intentionally introduced IAM permission misconfigurations.

The scope covers IAM Identity Center configuration, permission assignment, Amazon S3 access control, simulated unauthorized cross-team access, AWS CloudTrail log investigation using Amazon Athena, remediation, and post-remediation validation.

All testing was limited to the author's lab environment. Findings are based on the tests and evidence documented in this report. This project is a practical security demonstration and does not constitute a formal third-party security audit.

RAHUL REGHU RAJAN

TABLE OF CONTENTS

1. Introduction…… 01

2. Cloud Environment & Architecture…… 02

3. Security Implementation……..…… 05

4. IAM Misconfiguration Assessment…….. 08

5. Log Investigation & Analysis…… 12

6. Remediation & Validation…… 15

7. Results & Recommendations……..……. 18

8. Conclusion……. 20

9. References…… 21

10. Appendices……..… 22

10.1 Appendix A: IAM Policy Evidence…….. 22

10.2 Appendix B: Test Commands and Results……. 24

10.3 Appendix C: CloudTrail/Athena Evidence…… 26

10.4 Appendix D: Screenshots and Supporting Records…….. 28

RAHUL REGHU RAJAN

1. INTRODUCTION

1.1 Project Overview

The Cloud IAM Security & Monitoring Lab is a hands-on cloud security project built in a controlled AWS environment. It demonstrates Identity and Access Management (IAM), role-based access control, Amazon S3 resource permissions, audit logging, and security event investigation.

The project evaluates how excessive permissions can expose data across team boundaries. AWS CloudTrail and Amazon Athena are used to investigate recorded activity, while permission remediation and retesting validate the effectiveness of least-privilege access controls.

1.2 Objectives

- Configure a cloud environment with structured identity and access controls.
- Implement user, group, and permission-set assignments using IAM Identity Center.
- Assess the impact of excessive S3 permissions through controlled testing.
- Investigate relevant audit events using CloudTrail and Athena.
- Remove unauthorized access and validate the remediation through retesting.

1.3 Scope and Limitations

The project is limited to an authorized, controlled lab environment using test identities and sample S3 objects. The assessment focuses on IAM permission configuration, cross-team data access, audit evidence, remediation, and access validation.

The project does not represent an external compromise or a production security assessment. Findings are based on the configured lab environment and the available test evidence.

RAHUL REGHU RAJAN

2. CLOUD ENVIRONMENT & ARCHITECTURE

2.1 Environment Overview

The lab was implemented in a controlled AWS cloud environment under the simulated organization Nexora Systems. It uses centralized identity management, permission-based access to Amazon S3, audit logging, and SQL-based log investigation.

The environment was designed to demonstrate legitimate developer access, identify excessive cross-team permissions, and validate remediation through controlled testing.

2.2 Architecture and AWS Services

The architecture consists of the following components:

- **AWS IAM Identity Center:** Manages users, groups, and permission-set assignments.
- **IAM Permission Sets:** Define the AWS permissions available to the developer identity.
- **Amazon S3:** Hosts separate development and finance data buckets.
- **AWS CloudTrail:** Records management activity and configured S3 data events.
- **Amazon S3 (Log Storage):** Stores CloudTrail audit logs.
- **Amazon Athena:** Queries stored CloudTrail logs using SQL.
- **Kali Linux with AWS CLI:** Simulates activity using the authorized test identity and validates access before and after remediation.

RAHUL REGHU RAJAN

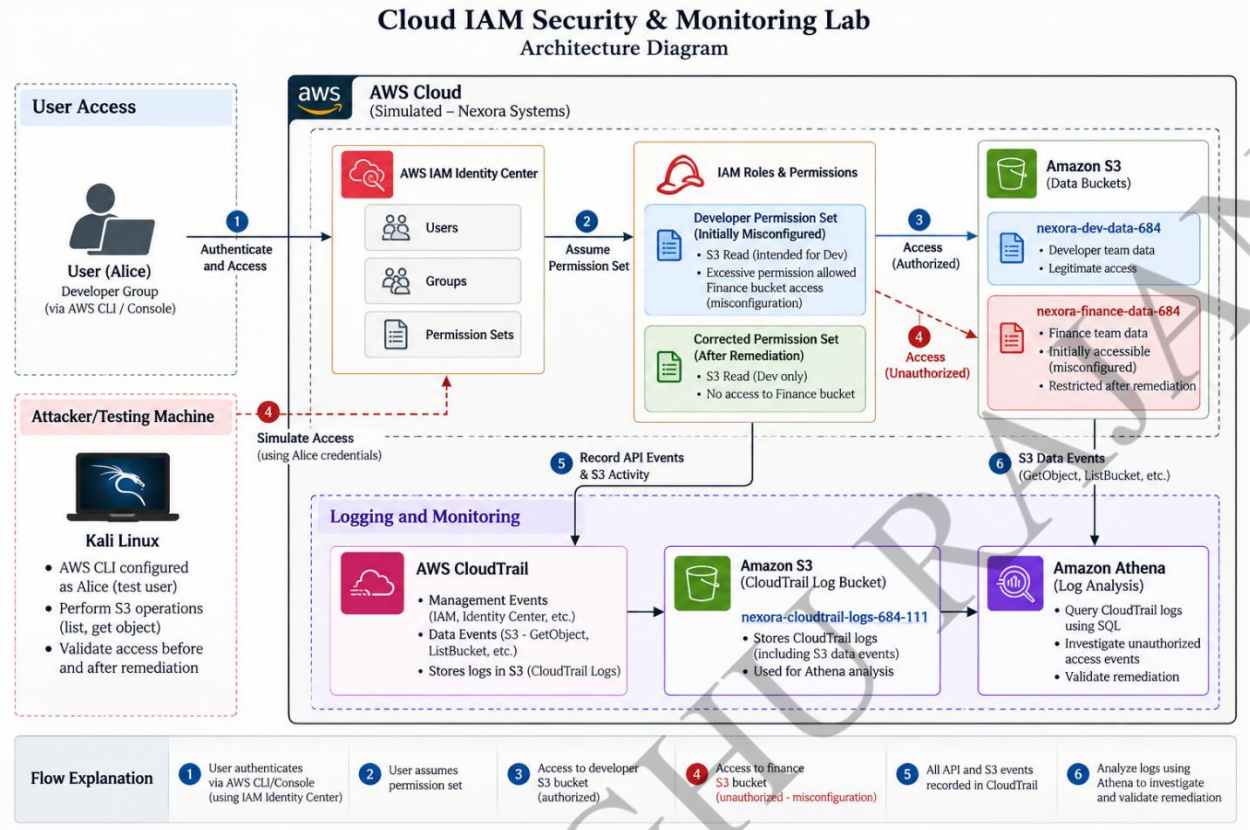


Figure 2.1: Cloud IAM Security & Monitoring Lab — Architecture Diagram.

2.3 IAM Users, Groups and Permission Sets

AWS IAM Identity Center was configured to manage access through users, groups, and permission sets. The test identity, dev.alice, was assigned the developer access configuration used during the assessment.

The developer permission set was intended to permit access to development resources. During the controlled assessment, an additional Finance S3 permission was temporarily introduced to demonstrate the security impact of excessive privileges.

RAHUL REGHURAJAN

2.4 S3 Bucket Structure and Access Boundaries

The lab uses separate S3 buckets to represent team-specific data boundaries.

S3 bucket	Purpose
nexora-dev-data-684	Development team data
nexora-finance-data-684	Finance team data
nexora-hr-data-684	HR team data
nexora-security-data-684	Security-related data
CloudTrail log bucket	Central storage for audit logs

The development identity was intended to access its authorized development resources only. Finance data served as the restricted resource for testing whether excessive permissions could bypass the intended access boundary.

RAHUL REGHU RAJAN

3. SECURITY IMPLEMENTATION

3.1 Root Account Security and Cost Management

The AWS account was secured by enabling multi-factor authentication (MFA) for the root user. Root access keys were not created, following the security practice of avoiding long-term credentials for unrestricted account access.

An AWS Budget was configured with cost alerts to monitor expenditure associated with the lab. These controls established a basic account-security and cost-management foundation before implementing the identity and monitoring components.

3.2 IAM Identity Center Configuration

AWS IAM Identity Center was configured to centralize workforce identity management and provide controlled access to AWS resources. Users, groups, and permission sets were created to organize access according to the intended responsibilities of each identity.

The developer test identity, dev.alice, was assigned access through the developer group and its associated permission set. This arrangement allowed the assessment to evaluate permissions granted to a developer identity without relying on root-user access.

The AWS CLI was configured on Kali Linux to interact with the environment using the test identity. This provided a repeatable method for validating access to S3 resources and observing the effect of permission changes.

3.3 Least-Privilege Access Design

The lab's access model was based on the principle of least privilege, under which an identity should receive only the permissions necessary to perform its assigned tasks.

The developer permission set was intended to provide the required access to the development S3 bucket. The Finance, HR, and security buckets represented separate data boundaries, allowing the lab to assess whether permissions were restricted to the appropriate resources.

RAHUL REGHU RAJAN

The assessment introduced a deliberate, temporary permission misconfiguration into the developer permission set. This additional permission allowed access to Finance data that was outside the developer's intended scope. The configuration was used exclusively for controlled testing and was subsequently removed during remediation.

3.4 CloudTrail Logging and Audit Configuration

AWS CloudTrail was configured to capture account activity for security investigation and auditing. The trail was configured for multi-Region logging, with log file validation enabled.

In addition to management events, S3 object-level data events were configured to record relevant operations against the selected resources. These events are important because actions such as object listing and retrieval provide evidence of how identities interact with stored data.

CloudTrail logs were delivered to a dedicated Amazon S3 bucket. The resulting records provided the audit evidence required to investigate the controlled access test, identify the associated identity and resource, and evaluate activity against the assessment timeline.

CloudTrail Event History alone was not sufficient for the required S3 object-level investigation. Therefore, the delivered log files were queried separately using Amazon Athena.

3.5 Amazon Athena Log Analysis Setup

Amazon Athena was configured to analyse CloudTrail records stored in Amazon S3. A table was created to make the stored log data available for SQL-based investigation.

Queries were used to filter recorded activity by event source, event name, time range, identity information, and S3 resource details. This approach reduced the need to inspect compressed log files manually and made it easier to isolate events relevant to the Finance access test.

Athena supported two important stages of the assessment: investigating the initial access activity and reviewing records associated with subsequent testing. The

RAHUL REGHURAJAN

resulting evidence helped correlate API activity with the test identity and the selected S3 resources.

Section outcome: The lab established identity-based access controls, separated team data into dedicated S3 buckets, and configured audit logging and SQL-based investigation. These components provided the foundation for testing an IAM permission misconfiguration and validating the resulting remediation.

RAHUL REGHU RAJAN

4. IAM MISCONFIGURATION ASSESSMENT

4.1 Assessment Scenario and Test Identity

The assessment was designed to evaluate whether a developer identity could access Amazon S3 resources outside its authorized scope due to an incorrectly configured permission set.

The test was conducted in the controlled Nexora Systems lab using the IAM Identity Center identity dev.alice. Kali Linux, with the AWS CLI configured, was used to perform S3 operations under this identity. Sample objects were used to validate access without involving real business data.

The assessment followed a controlled sequence: introduce a permission misconfiguration, validate the resulting access, collect audit evidence, remove the excessive permission, and retest the access boundaries.

4.2 Developer Permission Set Misconfiguration

The developer permission set, Nexora-Developer, was intended to provide access to development resources. A temporary statement named MisconfiguredFinanceReadAccess was added to simulate an overly permissive access configuration.

The statement granted the developer identity s3:ListBucket and s3:GetObject permissions on the Finance S3 bucket and its objects. These permissions exceeded the intended developer access scope and created an unintended cross-team access path.

The misconfiguration demonstrated how an incorrect resource ARN or an unnecessarily broad permission statement can weaken data isolation even when team-specific buckets are maintained.

RAHUL RECHU RAJAN

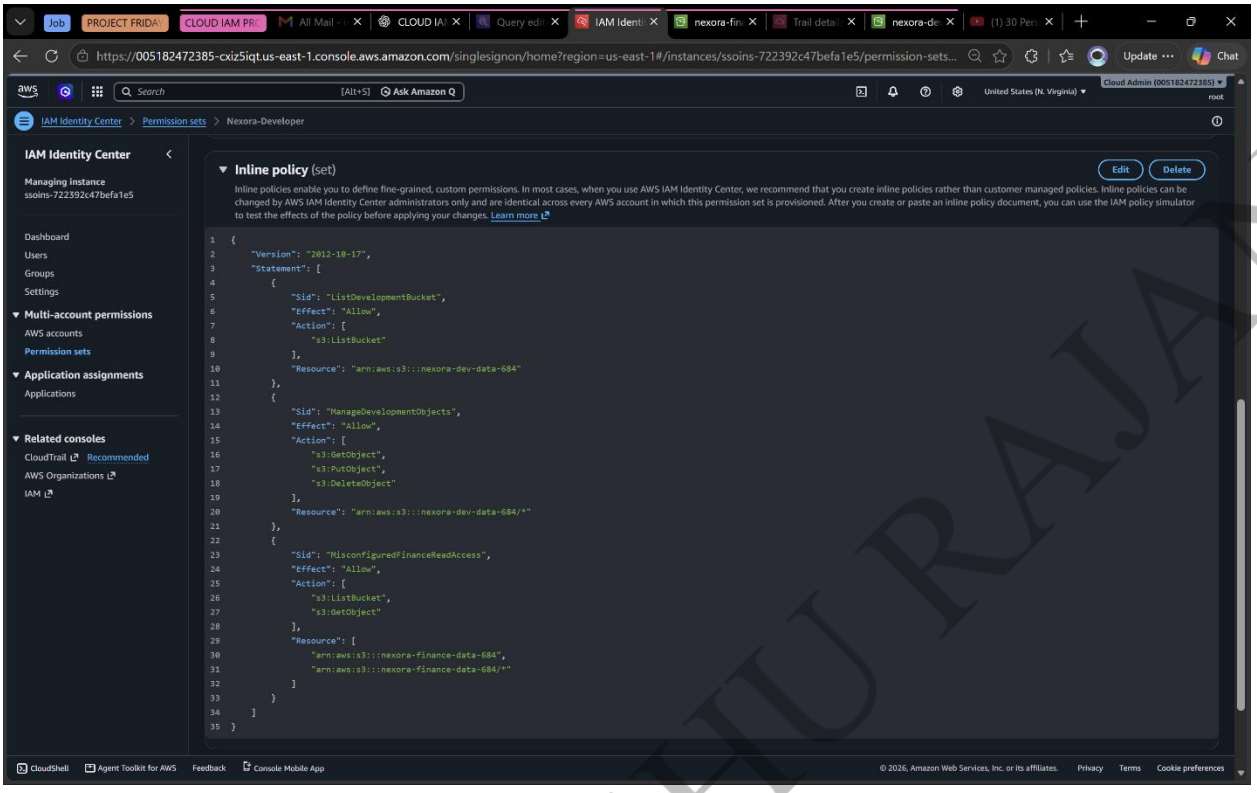


Figure 4.1: Temporary Finance access statement in the developer permission set.

4.3 Controlled Cross-Team S3 Access Test

The test was performed from Kali Linux using the AWS CLI and the alice-lab profile. The following operations were used to validate the Finance bucket access granted by the temporary misconfiguration.

aws sts get-caller-identity --profile alice-lab

aws s3 ls s3://nexora-finance-data-684 --profile alice-lab

aws s3 cp s3://nexora-finance-data-684/finance-test.txt.txt ./finance-test.txt.txt --profile alice-lab

RAHUL REGHU RAJAN

The identity check confirmed the AWS identity associated with the active profile. The S3 commands were used to test whether that identity could list the Finance bucket and retrieve the sample Finance object.

The test demonstrated that the developer identity could access Finance data despite Finance being outside its intended authorization scope. This established the practical impact of the excessive permission in the controlled lab.

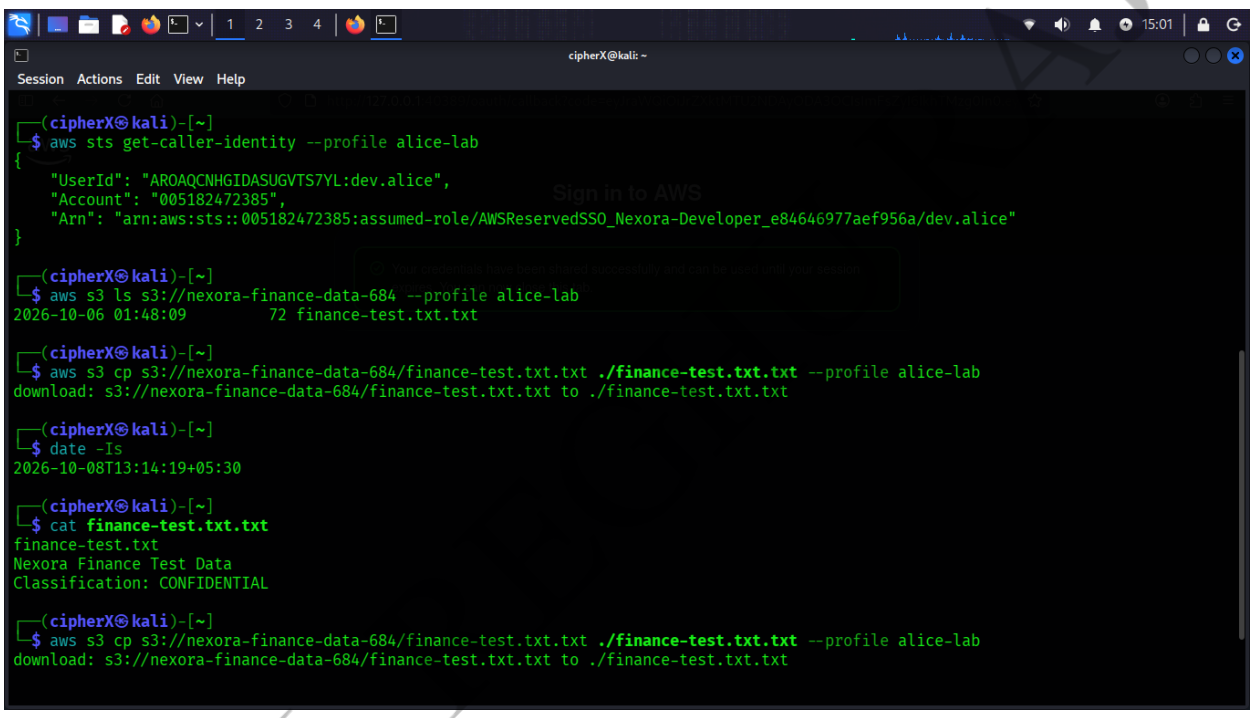


Figure 4.2: Successful cross-team Finance access from Kali Linux.

4.4 Evidence Collection and Findings

The assessment used two forms of evidence: command-line output from the controlled access test and CloudTrail records queried through Amazon Athena.

The Athena investigation identified successful S3 activity associated with the assumed role for dev.alice, including a GetObject event for finance-test.txt.txt in nexora-finance-data-684. The recorded event timestamp was 8 October 2026, 07:53:56 UTC (13:23:56 IST), consistent with the reported test window.

RAHUL ARJAN

The event record linked the test identity to the Finance object retrieval and provided audit evidence of the access. The result demonstrated that the temporary permission misconfiguration allowed a developer identity to cross its intended data boundary.

Finding: Excessive S3 permissions in the developer permission set enabled unintended access to Finance data. The configuration required remediation to restore least-privilege access.

RAHUL REGHU RAJAN

5. LOG INVESTIGATION & ANALYSIS

5.1 CloudTrail Data Events

AWS CloudTrail was configured to record S3 object-level data events for the lab environment. These events provide visibility into actions performed on objects stored in the configured S3 buckets, including object retrieval operations.

Unlike management events, S3 object-level data events are not normally displayed in CloudTrail Event History. Therefore, the investigation used the CloudTrail logs delivered to the designated S3 logging bucket and queried them through Amazon Athena.

This logging configuration enabled the investigation to examine activity associated with the developer test identity and determine whether the Finance bucket had been accessed during the controlled assessment.

5.2 Athena Queries and Event Analysis

Amazon Athena was used to query the CloudTrail log data stored in Amazon S3. The queries filtered records by event name, identity, time, and relevant S3 resource details.

The investigation focused on S3 operations associated with the dev.alice test identity, particularly GetObject events involving the Finance bucket. The recorded event fields included the event timestamp, event name, identity ARN, source IP address, request parameters, and error details where available.

Filtering these records helped identify relevant activity without manually examining every CloudTrail log file.

RAHUL PEGHU RAJAN

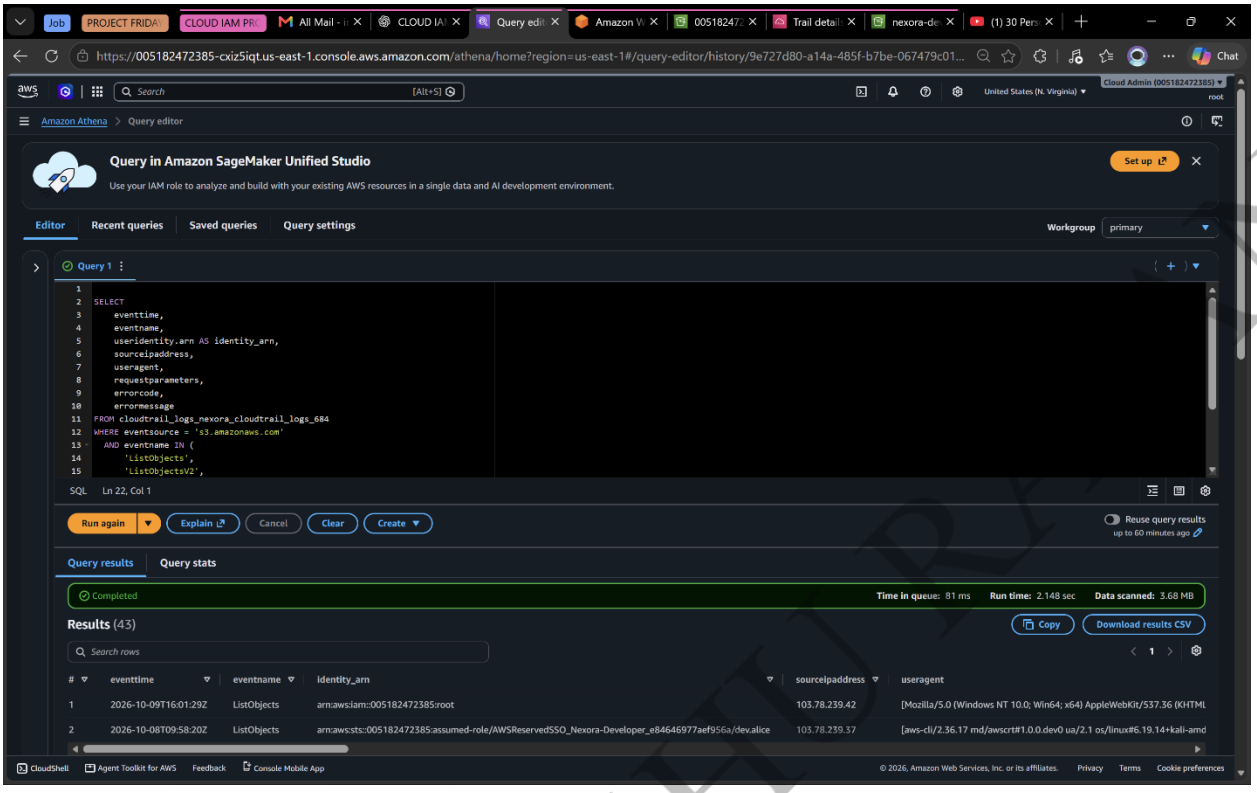


Figure 5.1: Amazon Athena query results used to investigate CloudTrail activity.

5.3 Identification of Unauthorized Finance Data Access

The investigation identified a successful GetObject event associated with the developer's assumed role. The event was recorded at 8 October 2026, 07:53:56 UTC (13:23:56 IST) and referenced the object finance-test.txt.txt in the nexora-finance-data-684 bucket.

The timestamp was consistent with the reported Kali Linux test window. When considered alongside the AWS CLI output captured during the test, the event provided supporting audit evidence that the developer identity retrieved the Finance test object while the temporary excessive permissions were in place.

The successful request demonstrated that the temporary permission configuration allowed access beyond the developer's intended authorization boundary.

RAHUL REGHUVANSHI

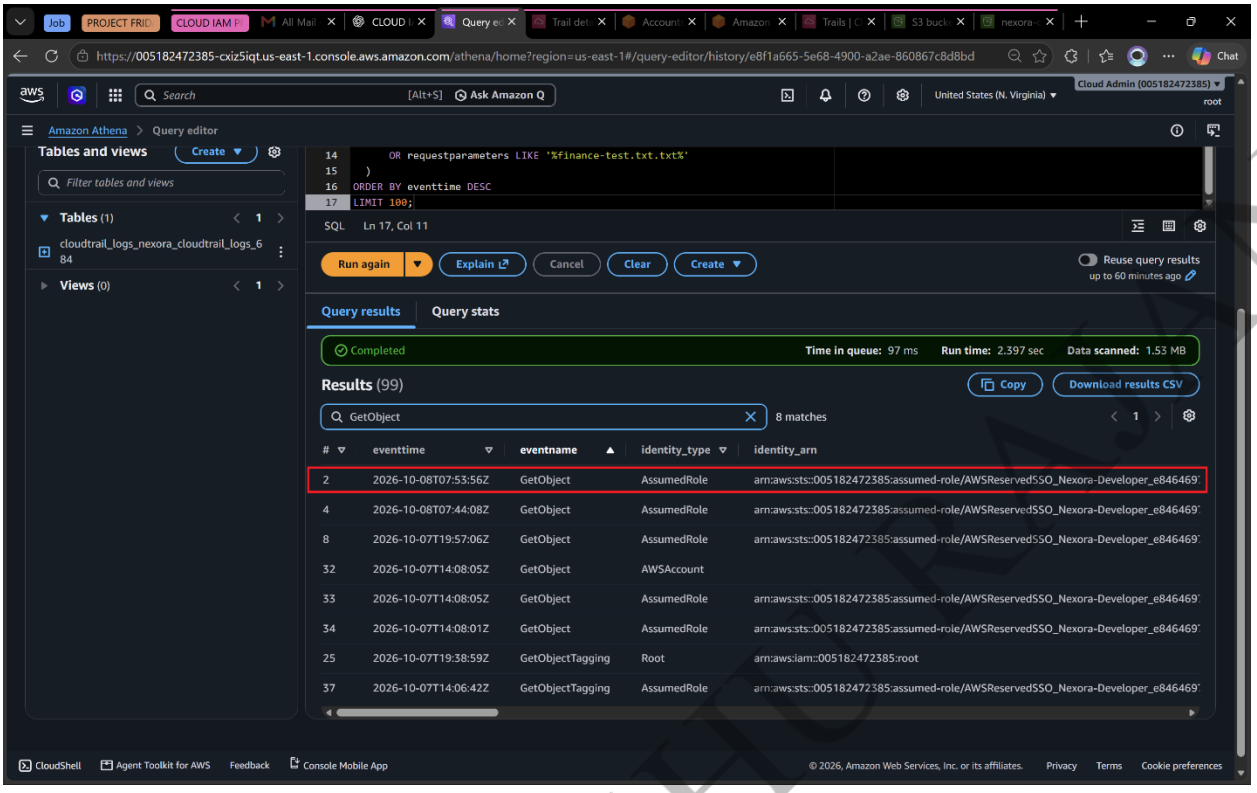


Figure 5.2: CloudTrail record of the successful Finance object retrieval.

5.4 Security Impact and Risk Assessment

The assessment identified an access-control weakness caused by excessive permissions assigned to the Developer permission set. The permission allowed the developer test identity to access Finance data outside its intended scope.

In a real cloud environment, similar misconfigurations could expose confidential files to users who do not require access to them. The impact would depend on the sensitivity of the stored data, the permissions granted, and whether the activity was detected and addressed promptly.

The investigation demonstrated the importance of enabling appropriate S3 data-event logging, reviewing CloudTrail records, and applying least-privilege permissions. The findings informed the remediation and validation activities documented in Section 6.

RAHUL REGHUNATHAN

6. REMEDIATION & VALIDATION

6.1 Removal of Excessive Permissions

Following the investigation, the temporary MisconfiguredFinanceReadAccess policy statement was removed from the Nexora-Developer permission set. This statement had allowed the developer test identity to list objects in the Finance S3 bucket and retrieve Finance objects beyond its intended access scope.

The remediation restored the intended separation between the Development and Finance environments. The Developer permission set was reviewed to ensure that the temporary Finance permissions were no longer present.

This change applied the principle of least privilege by restricting the developer identity to the resources required for its designated role.

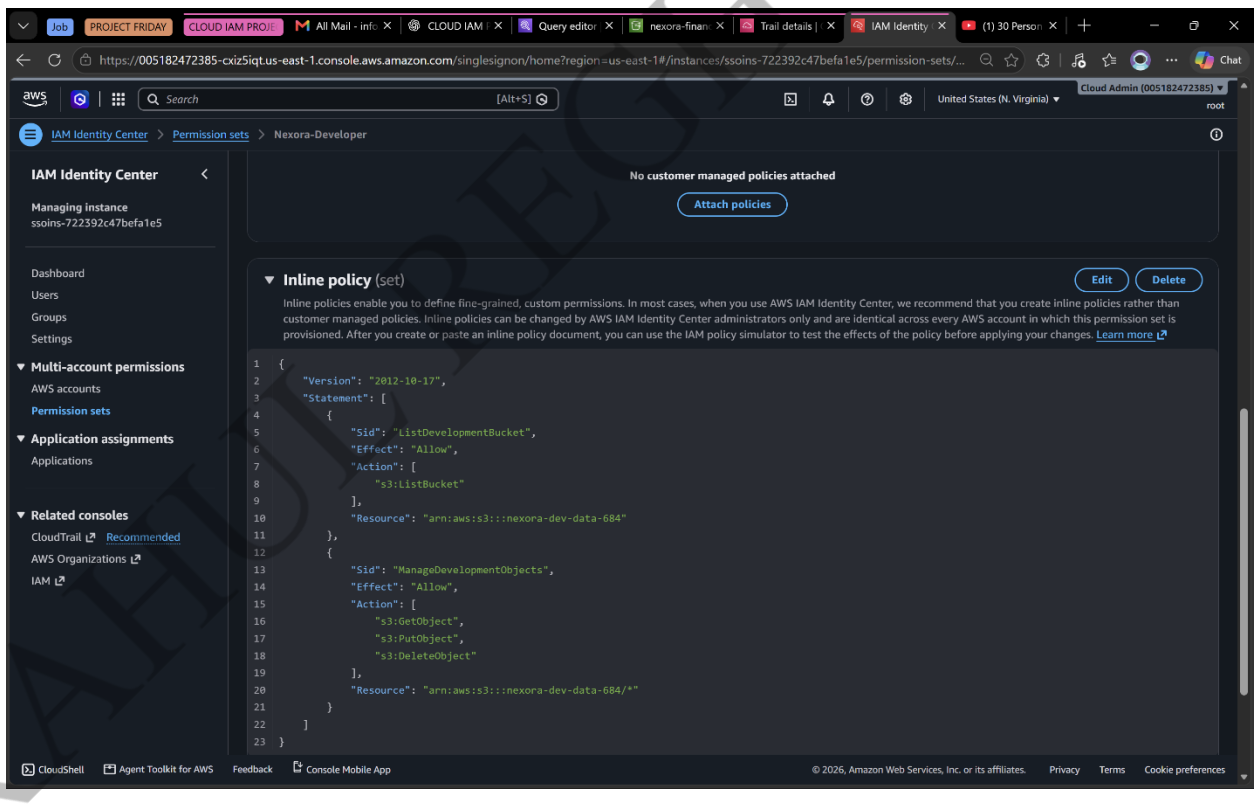


Figure 6.1: Removal of temporary Finance access permissions from the Developer permission set.

RAHUL PEGHU RAJAN

6.2 Post-Remediation Access Testing

After removing the excessive permissions, the dev.alice test identity was used to repeat the Finance access test from Kali Linux through the AWS CLI.

The purpose of this test was to confirm that the identity could no longer access Finance resources through the previously misconfigured permission set. The test was performed using the same lab identity and Finance bucket used during the initial assessment.

The retest provided a direct comparison between the initial configuration, which permitted cross-team access, and the remediated configuration, which restored the intended access boundary.

6.3 Validation of Denied Finance Access

During post-remediation validation, an attempt to list objects in the Finance bucket was denied. The observed AccessDenied response indicated that the developer identity no longer had the required authorization for that operation.

The corresponding CloudTrail records were also investigated through Amazon Athena. The audit data included a denied Finance ListObjects request associated with the developer's assumed role, recorded at 8 October 2026, 09:58:20 UTC (15:28:20 IST).

This record supported the finding that Finance access was denied after remediation. Together, the CLI response and audit record demonstrated that the excessive permission had been removed and that the access restriction was being enforced.

RAHUL REGHU RAJAN

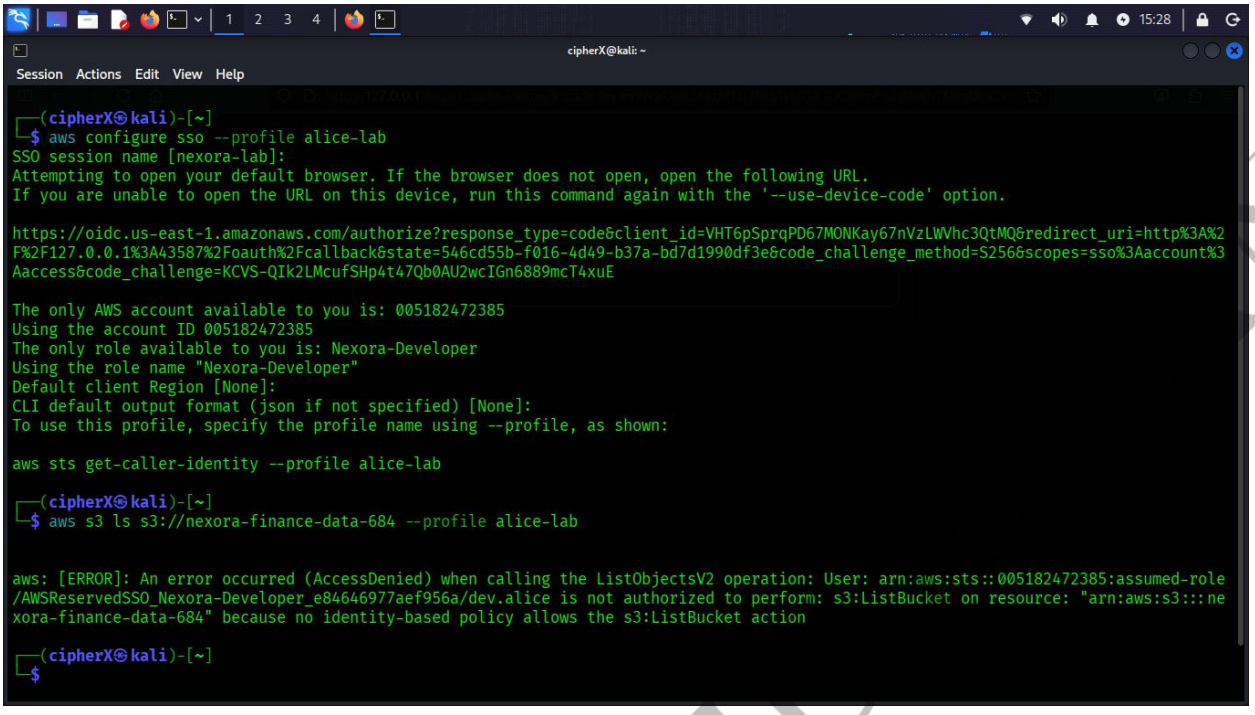


Figure 6.2: Post-remediation denial of the developer identity's Finance access.

6.4 Confirmation of Authorized Development Access

The remediation was intended to restrict access to Finance data without unnecessarily disrupting the developer's legitimate work. The Development bucket remained the designated resource for the developer identity.

Where authorized Development access was tested successfully, the result confirmed that the remediation preserved the required access while restricting cross-team Finance access. This distinction is important because effective least-privilege enforcement should prevent unauthorized access without blocking legitimate role-related activity.

The assessment therefore demonstrated the value of testing both sides of an access boundary: access that should be denied and access that should remain permitted.

RAHUL REGHU

7. RESULTS & RECOMMENDATIONS

7.1 Assessment Results

The Cloud IAM Security & Monitoring Lab demonstrated how an excessive permission assignment can weaken access boundaries between teams in an AWS environment. During the controlled assessment, the developer test identity, dev.alice, was able to access a Finance S3 object while the temporary misconfiguration was active.

The investigation used AWS CloudTrail records queried through Amazon Athena to examine the relevant S3 activity. Following remediation, the temporary Finance permissions were removed from the Nexora-Developer permission set. A subsequent attempt to list the Finance bucket from Kali Linux returned an AccessDenied response.

The results demonstrated the importance of correct permission-set configuration, audit logging, and post-remediation validation.

7.2 Security Improvements Implemented

The following security controls and assessment activities were implemented as part of the project:

- Enabled multi-factor authentication for the AWS root account and avoided using root access keys.
- Configured an AWS Budget with alerts to support cost awareness.
- Used IAM Identity Center to manage users, groups, and permission sets.
- Separated Development, Finance, HR, and Security data into dedicated S3 buckets.
- Configured AWS CloudTrail to record relevant management activity and S3 object-level data events.
- Used Amazon Athena to query and investigate CloudTrail records.
- Identified and removed temporary excessive permissions from the Developer permission set.

RAHUL REGHU RAJAN

- Re-tested Finance access after remediation and observed an AccessDenied response.

Together, these activities demonstrated a practical workflow for identifying, investigating, and remediating a cloud IAM misconfiguration.

7.3 Recommendations and Future Enhancements

Based on the assessment findings, the following improvements are recommended for a production cloud environment:

1. **Maintain least-privilege permissions:** Grant users and groups only the permissions required for their roles, and review permission sets regularly.
2. **Use separate access boundaries:** Keep sensitive Finance, HR, and Security resources isolated from general Development access.
3. **Monitor S3 data events:** Enable appropriate CloudTrail data-event logging for sensitive buckets and review relevant access activity.
4. **Investigate denied and unexpected requests:** Use CloudTrail and query tools such as Athena to investigate suspicious access patterns and repeated authorization failures.
5. **Validate policy changes:** Test both permitted and denied actions after modifying IAM policies or permission sets.
6. **Protect audit records:** Restrict access to CloudTrail log storage and consider additional integrity and retention controls appropriate to the environment.
7. **Review cloud costs:** Continue monitoring AWS Budget alerts and remove unused resources when the lab is not in use.

Future enhancements could include automated alerts for unexpected cross-team access, scheduled permission reviews, and more advanced reporting of CloudTrail events. These are proposed improvements and are not claimed as implemented features of the current lab.

RAHUL RECHU RAJAN

8. CONCLUSION

The Cloud IAM Security & Monitoring Lab provided a practical demonstration of cloud identity and access management, security monitoring, and IAM misconfiguration remediation using Amazon Web Services (AWS).

The assessment focused on identifying the security impact of excessive permissions assigned to the Developer permission set. During the controlled test, the dev.alice identity was able to access a Finance S3 object beyond its intended authorization scope. AWS CloudTrail records were subsequently investigated through Amazon Athena to examine the relevant access activity and support the assessment findings.

The temporary excessive permissions were then removed from the Nexora-Developer permission set. Post-remediation testing from Kali Linux returned an AccessDenied response when the developer identity attempted to list the Finance bucket, demonstrating that the access restriction was enforced for that operation.

The project also incorporated foundational cloud security practices, including root account MFA, cost monitoring, centralized identity management through IAM Identity Center, separation of team data into dedicated S3 buckets, and audit logging through CloudTrail.

Overall, the project reinforced the importance of least-privilege access, effective audit logging, evidence-based investigation, and validation after security changes. It provided hands-on experience with AWS IAM concepts, S3 access controls, AWS CLI testing, CloudTrail event analysis, and Amazon Athena queries.

The lab was conducted in a controlled environment for educational and portfolio purposes. Its findings illustrate how cloud IAM misconfigurations can be identified, investigated, and remediated through a structured security assessment process.

RAHUL REGHURAJAN

9. REFERENCES

The following official documentation was consulted to support the configuration, implementation, and analysis activities performed in this project.

1. Amazon Web Services (AWS). *Root User Best Practices for Your AWS Account.* AWS Identity and Access Management Documentation. Available at: https://docs.aws.amazon.com/IAM/latest/UserGuide/root-user-best-practices.html
2. Amazon Web Services (AWS). *Create, Manage, and Delete Permission Sets.* AWS IAM Identity Center User Guide. Available at: https://docs.aws.amazon.com/singlesignon/latest/userguide/permissionsets.html
3. Amazon Web Services (AWS). *Amazon S3 CloudTrail Events.* Amazon S3 User Guide. Available at: https://docs.aws.amazon.com/AmazonS3/latest/userguide/cloudtrail-logging-s3-info.html
4. Amazon Web Services (AWS). *Query AWS CloudTrail Logs.* Amazon Athena User Guide. Available at: https://docs.aws.amazon.com/athena/latest/ug/cloudtrail-logs.html
5. Amazon Web Services (AWS). *Required Permissions for Amazon S3 API Operations.* Amazon S3 User Guide. Available at: https://docs.aws.amazon.com/AmazonS3/latest/userguide/using-with-s3-policy-actions.html
6. Amazon Web Services (AWS). *Multi-Factor Authentication for AWS Account Root User.* AWS Identity and Access Management Documentation. Available at: https://docs.aws.amazon.com/IAM/latest/UserGuide/enable-mfa-for-root.html
7. Amazon Web Services (AWS). *Security Control Recommendations for Managing Identity and Access.* AWS Prescriptive Guidance. Available at: https://docs.aws.amazon.com/prescriptive-guidance/latest/security-controls-by-caf-capability/identity-and-access-controls.html

RAHUL REGHUPAJAN

10. APPENDICES

10.1 Appendix A — IAM Policy Evidence

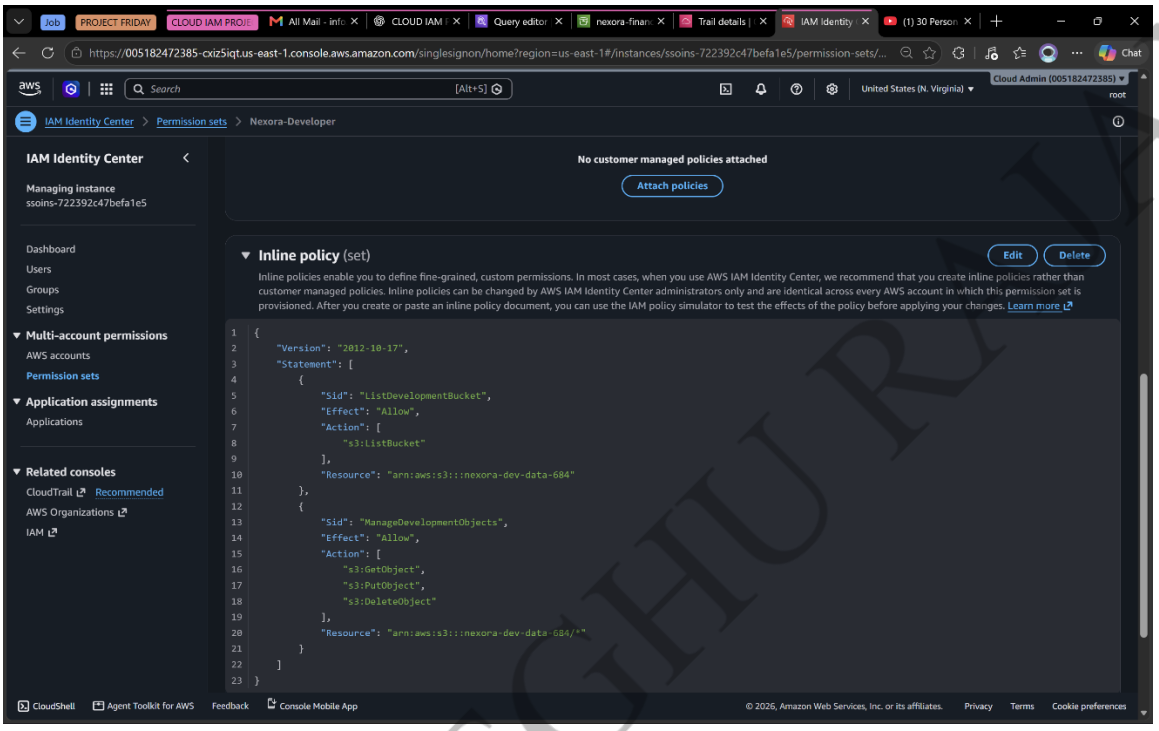


Figure 10.1: Remediated Developer Permission Set Policy

RAHUL REGHU RAJAN

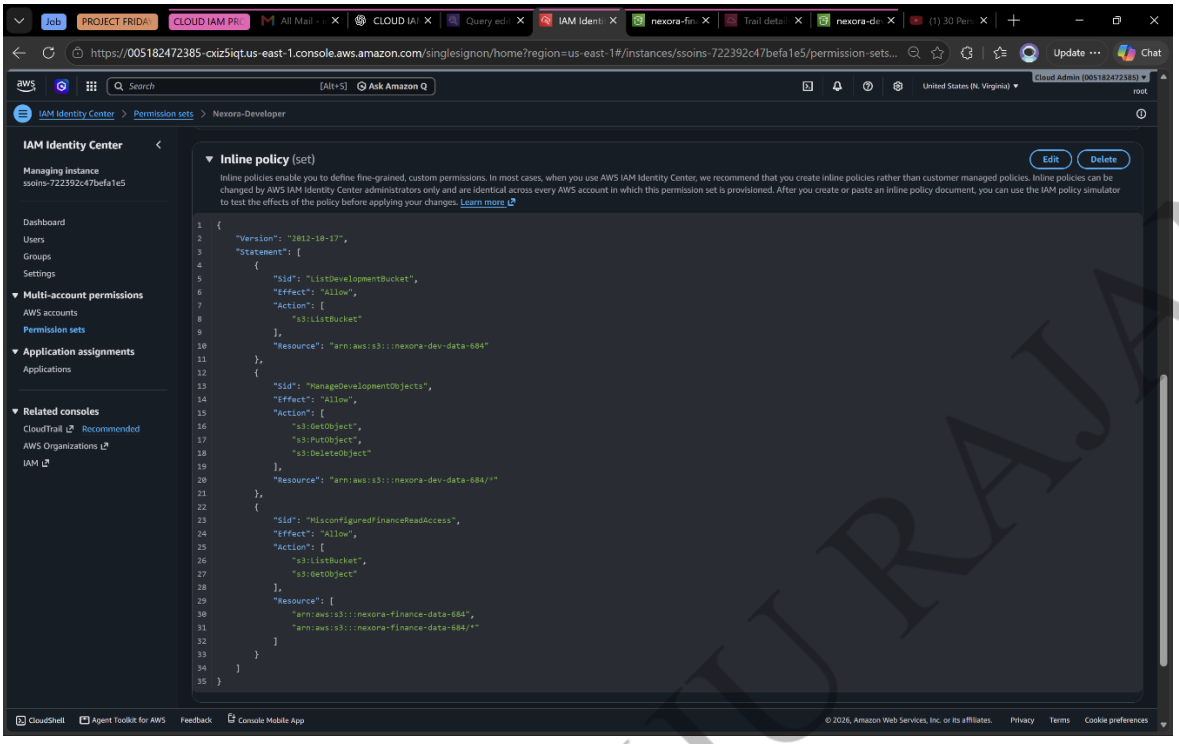


Figure 10.2: Misconfigured Finance Read Access Policy

RAHUL REGHU RAJAN

10.2 Appendix B — Test Commands and Results

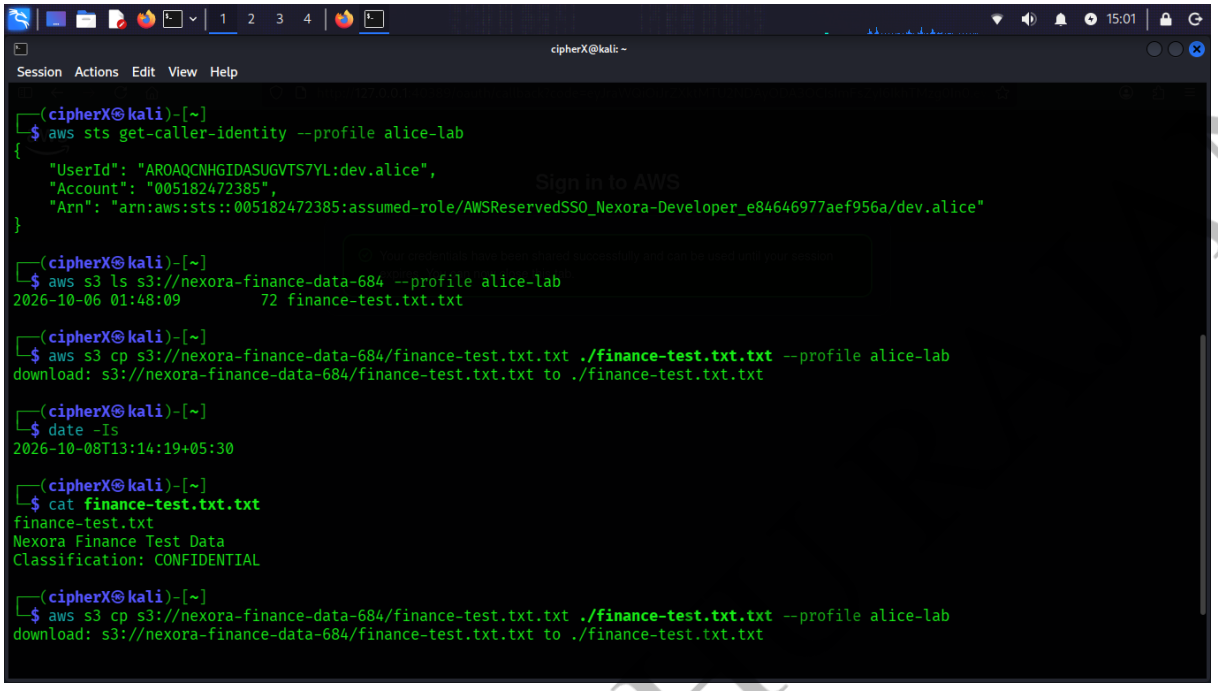


Figure 10.3: AWS CLI Identity Verification

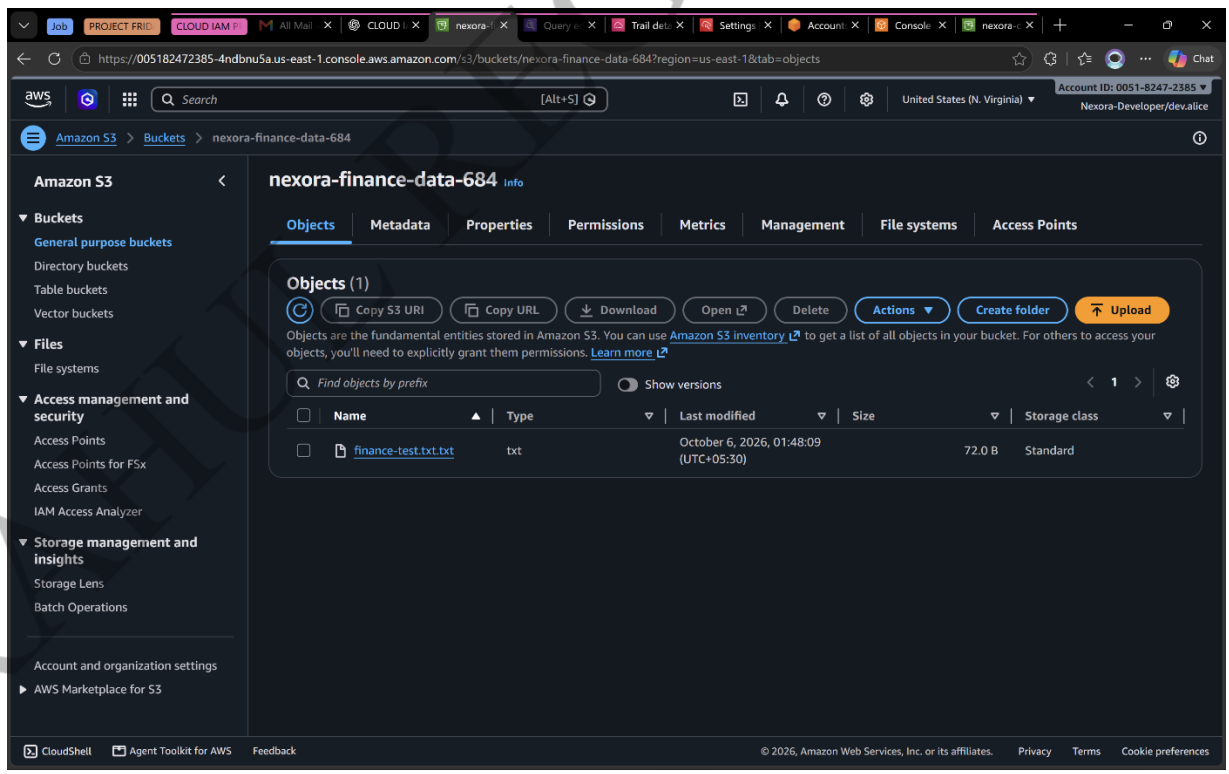


Figure 10.4: Successful Finance Access Before Remediation

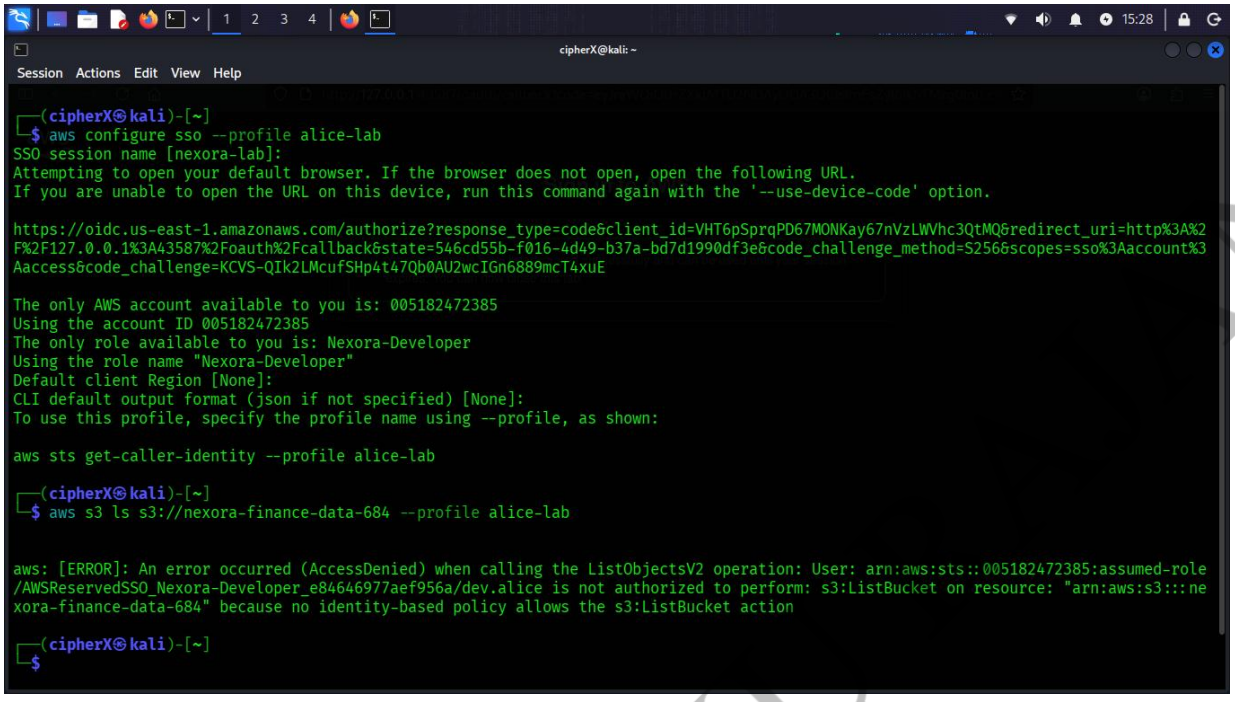


Figure 10.5: Finance Access Denied After Remediation

RAHUL REGHU

10.3 Appendix C — CloudTrail and Athena Evidence

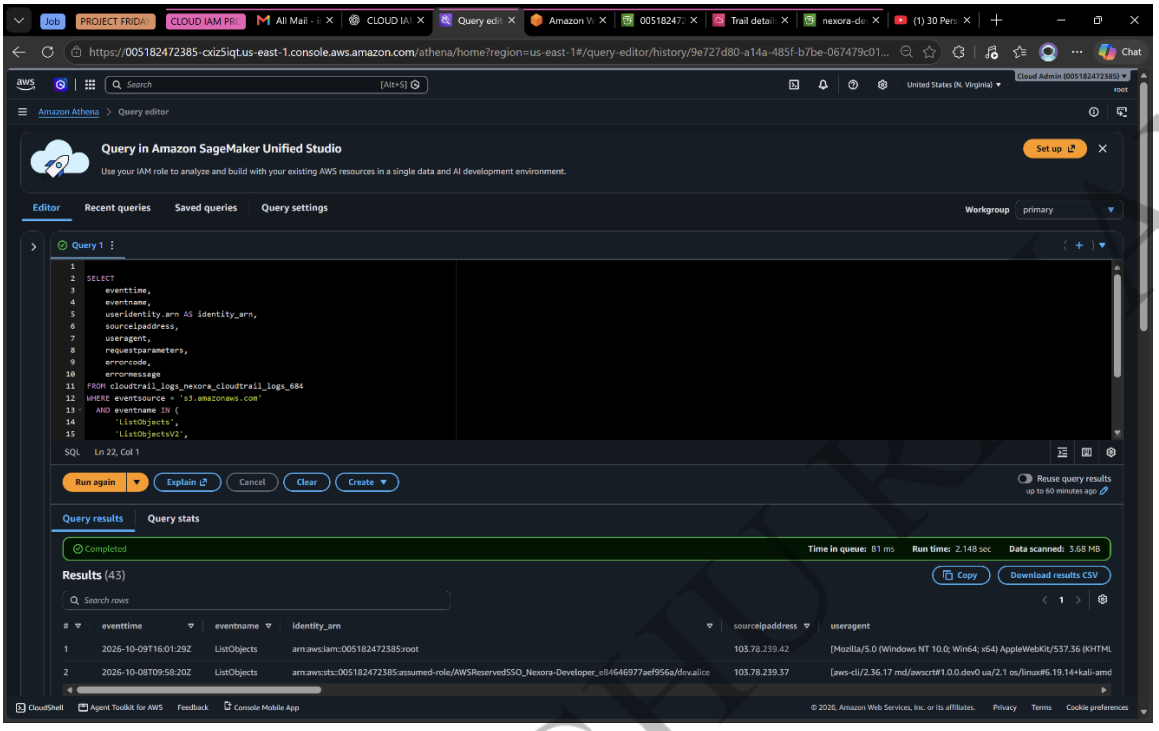


Figure 10.6: Athena Query for Finance Access Events

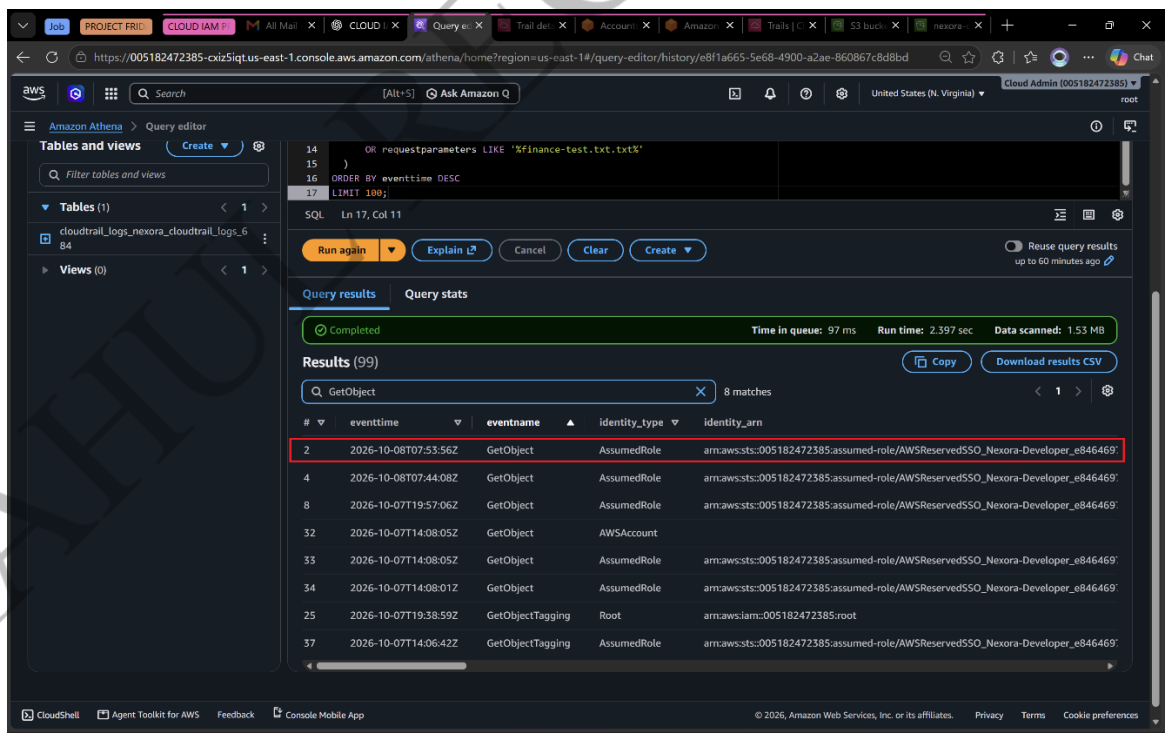


Figure 10.7: CloudTrail Evidence of Successful Finance Object Retrieval

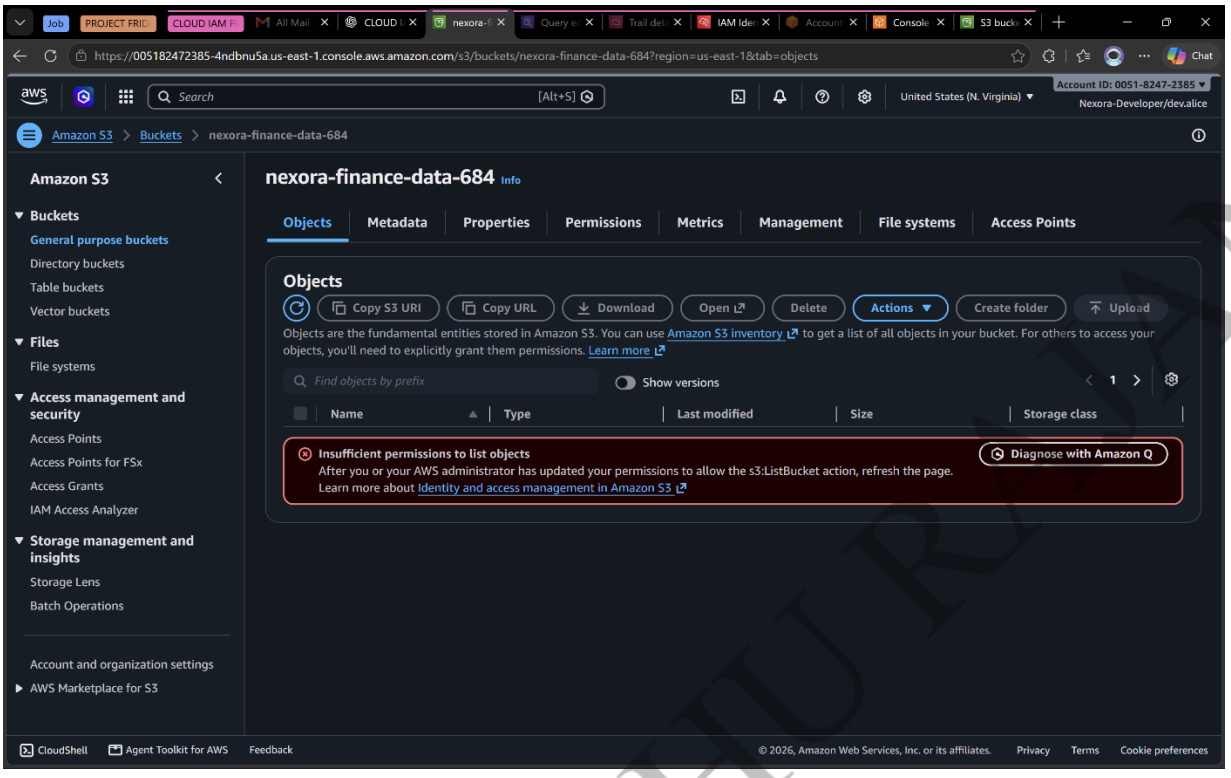


Figure 10.8: Evidence of Denied Finance Access

RAHUL REGHUVARAN

10.4 Appendix D — Screenshots and Supporting Records

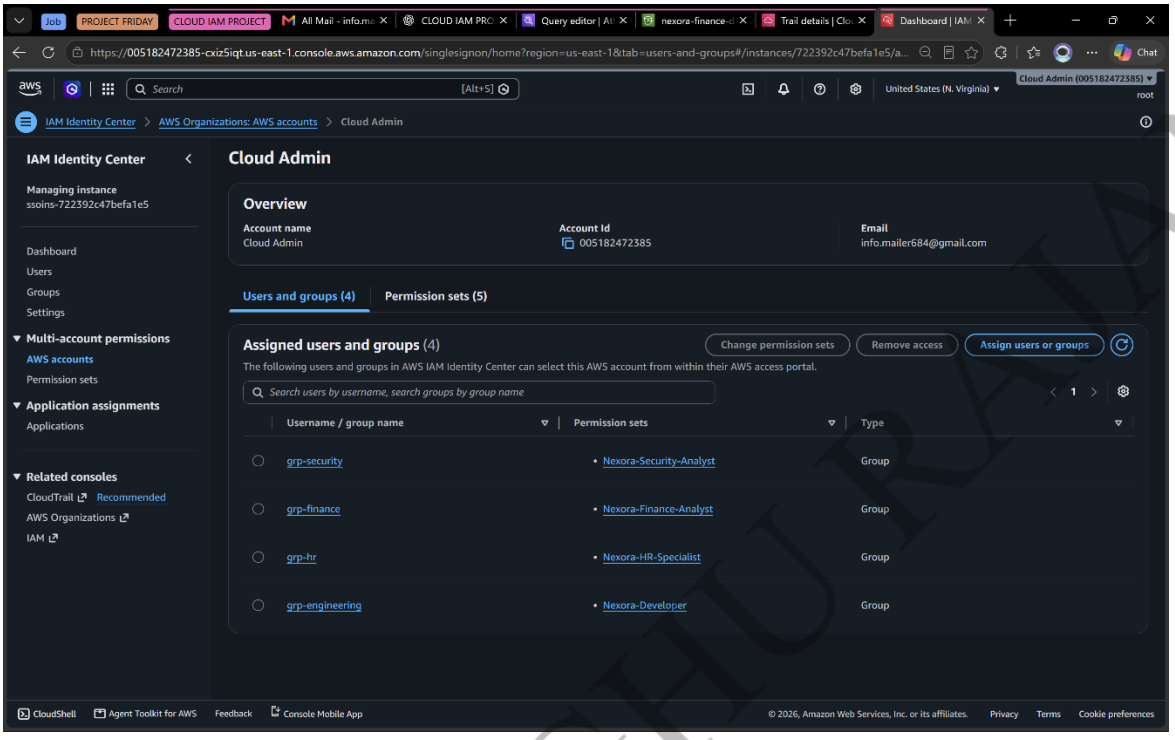


Figure 10.9: IAM Identity Center Configuration

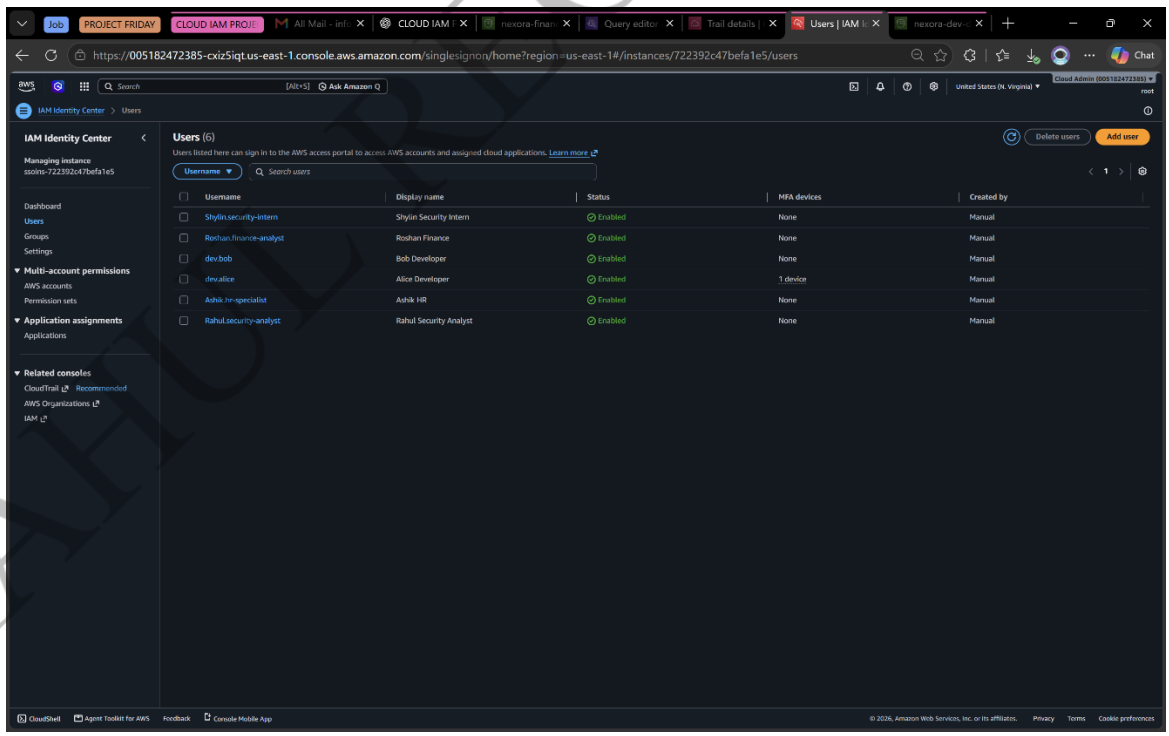


Figure 10.10: IAM Identity Center Users

RAHUL SEGHURAN

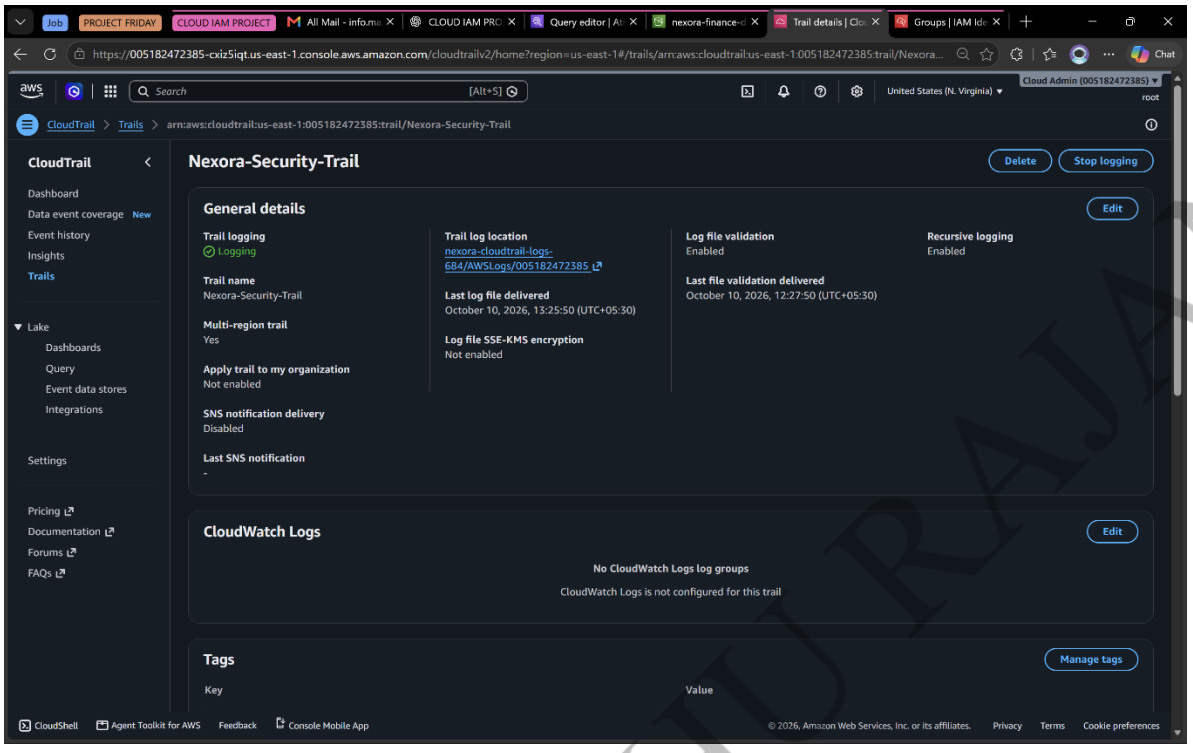


Figure 10.11: CloudTrail Audit Configuration

RAHUL REGHUJRAJAN